ModelGate

We run a model's code in a trap before it runs on your machine.

github.com/rkottomt/modelgate

WHY WE BUILT MODELGATE

31 Hugging Face models installed miners and backdoors.

32,000

downloads of models with hidden code, reported by Pluto Security on 29 October 2026.

`Pluto Security, "Load/Mine"`

How it ran	Automatically, the moment someone loaded the model with a common setting: `trust_remote_code=True`.
What it did	Installed crypto-miners and backdoors. A second wave followed, and copies were still live days later.
Who missed it	**Hugging Face's, Protect AI's and JFrog's scanners all missed it.**

Millions of people run open models on their own machines.

18M+

people use Hugging Face to share and download over 3 million models

NVIDIA, Sep 2026

8.9M

developers run open models locally with Ollama, used by 85% of the Fortune 500

Ollama, Jul 2026

36,697

Hugging Face models need `trust_remote_code` to load, so they run their own code

arXiv 2601.14163, Jan 2026

> Every one of those loads runs on someone's own hardware, with their own keys.

MODELGATE

One import. The code is checked before it runs.

```
import modelgate.auto
```

01

Fetch

The code only, locked to one commit. Never the weights.

02

Read

Risky calls, decoded blobs, notes aimed at AI reviewers.

03

Run it in a trap

A sealed container, watched at the kernel level.

04

Decide

Fixed rules. An AI explains the result but can't change it.

Three seconds in the trap

Sealed

No network

Read-only disk, no privileges

Files piped in, nothing mounted

Baited

Looks like a GPU server

Decoy SSH key

Fresh fake tokens every scan

Exercised

Told a GPU exists

Builds a tiny model

Runs it, saves it, loads the tokenizer

Watched

Kernel logs every connection and program

Python names the exact line

```
+0.015 s  connect 203.0.113.5:3333  KERNEL  PYTHON  modeling_lazy.py:19  during forward pass
```

About 3 seconds per repo (2.5–4.6 s measured). A hang, a crash or no Docker means Block.

What makes a model unsafe

Block

ANY ONE OF THESE

- Opens a network connection
- Starts a program or a shell
- Reads keys, tokens or credential files
- Hides a program in memory or renames its process
- Decodes hidden data and runs it
- Ships compiled code we can't read
- Can't be fully checked: crash, timeout, no sandbox

Warn

A PERSON SHOULD LOOK

- Network or shell code that didn't fire
- `exec`, `eval` or encoded blobs
- Pulls code from another repo
- Text aimed at AI reviewers
- Parts of the model we couldn't run

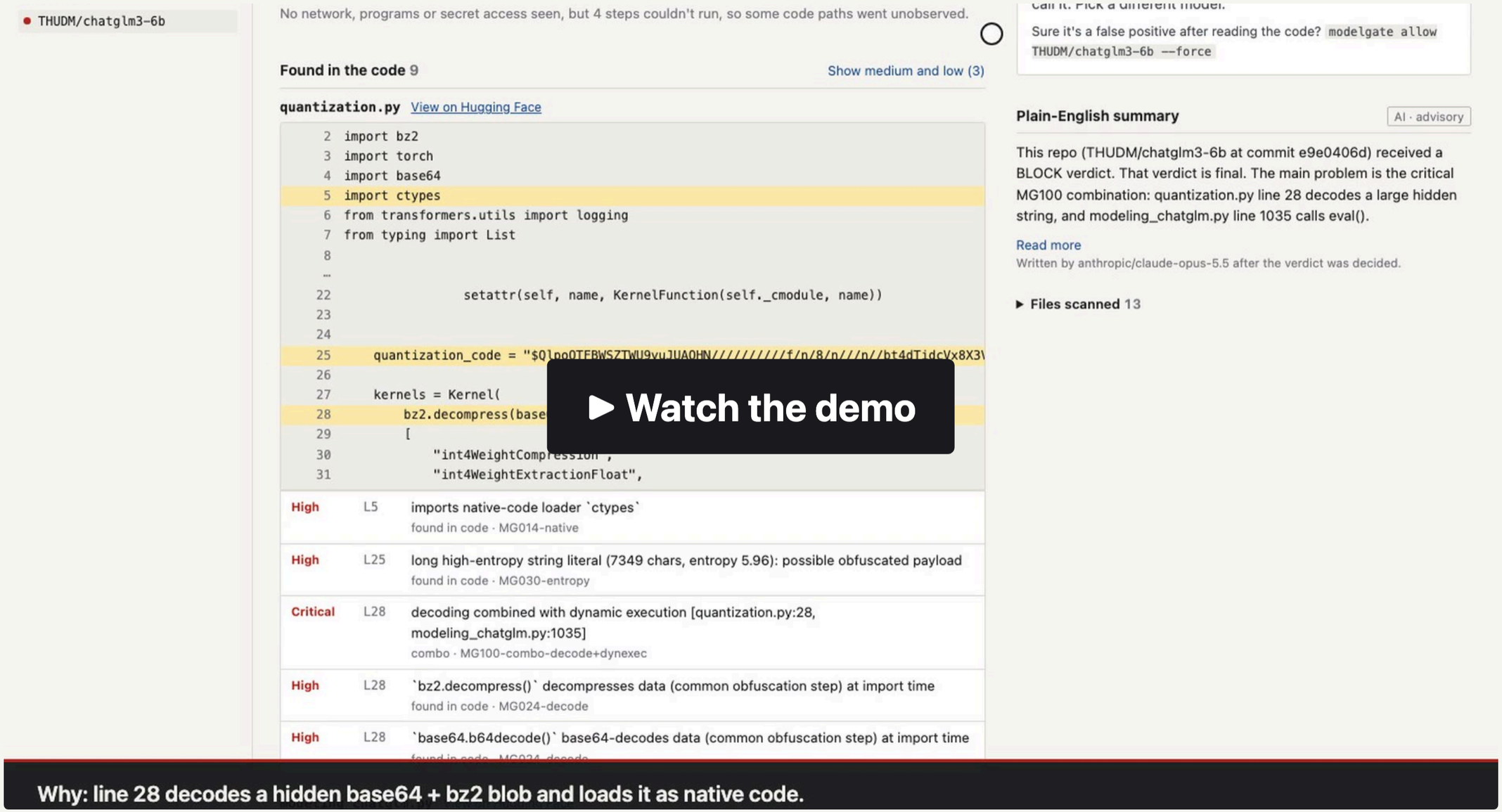
Allow

ONLY IF

- None of the above, in the code or when run
- The load is locked to the exact commit we checked

Checked in the code and when it runs in the trap. Fixed rules decide, never the AI.

Demo



Why: line 28 decodes a hidden base64 + bz2 blob and loads it as native code.

Already checked: 37 popular open-source models.

37

of the most-used custom-code models: Phi, Qwen, DeepSeek, GLM, InternVL, Jina, Nomic and more

107 s

to check all 37, about 2.9 seconds each, with 29 run inside the trap

0

tried to connect out, start a program or touch keys

Plus	6 of 6 attack imitations blocked, including one that only fires on a GPU.
Fail closed	7 models crashed on the current transformers version. We can't watch them run, so we don't let them load.

The code runs in our trap before it runs on your GPU.

Next: scan every new commit on the Hub, so a model is checked before anyone downloads it.

github.com/rkottomt/modelgate